

OSRA Executive Assessment

OPERATIONAL SUBSTRATE RISK AUDIT

The audit that your compliance framework assumes someone already did.

OSRA maps where AI infrastructure risk converges beneath the governance layer, in the substrate that no existing framework audits.

THE METHODOLOGY

Phase 1: Substrate Mapping

What does your AI system actually depend on? Map the real infrastructure chain — model, compute, data, energy, contracts, geography.

Phase 2: Failure Surface Analysis

For each dependency, what does failure look like? Who would notice? Where are the silent failures that produce no error signal?

Phase 3: Trust Surface Audit

Where are you trusting vendor claims, certifications, and SLAs you have never independently verified? Including human-in-the-loop effectiveness.

Phase 4: Convergence Mapping

Where do substrate risks, undetected failures, and unverified trust overlap? That convergence is where real exposure concentrates.

DELIVERABLES

- Substrate Risk Map with dependency chain analysis
- Failure Surface Register with severity and silent failure flags
- Trust Surface Register with verification status
- Convergence Risk Summary — ranked, scored, actionable
- 90-day remediation sequence with ownership
- One-page board summary for governance reporting
- One presentation to leadership team

ENGAGEMENT SHAPE

Duration: 2–3 weeks elapsed

Effort: 6–8 working days

Scope: Document review, 5–8 stakeholder interviews (CISO, CTO, compliance, infrastructure, vendor management), substrate mapping against the OSRA framework, board-ready findings report, one presentation to leadership.

INVESTMENT

€9,500 mid-market **€14,500** regulated / complex
Fixed scope, fixed price. No day-rate uncertainty.

WHO THIS IS FOR

CISOs, CTOs, and boards of organisations deploying AI into regulated or critical environments. Particularly relevant for DORA-regulated financial institutions, EU AI Act high-risk system deployers, and NIS2-designated entities.

EVIDENCE BASE

OSRA is built on documented research: 12 governance frameworks analysed clause-by-clause, 15 existing methodologies surveyed, regulatory liability mapped across 10+ jurisdictions, scoring calibrated across 5 sectors.

The methodology and templates are open source on GitHub while the assessment applies them to your specific environment.

PROOF ARTEFACT

A complete four-phase worked example (EuroBank Sentinel, a DORA-regulated bank, AI fraud detection) is published at marcobrondani.com/osra. It demonstrates what the assessment produces and what the findings look like.

Marco Brondani

30 years across CISO and CTO roles · US, Europe, Japan, APAC · Author of The Split Problem (2026)
m@marcobrondani.com · marcobrondani.com · linkedin.com/in/marcobrondani